



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2025-66376 Zimbra Collaboration Suite Exploitation Daily Priority

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-08-01
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2025-66376 Zimbra Collaboration Suite Exploitation Daily Priority - CVE / Vulnerability Threat Intelligence Report

Published: 2026-08-01 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2025-66376 Zimbra Collaboration Suite Exploitation Daily Priority

1. Executive Summary

CVE-2025-66376 is a daily defender priority because it affects a security-relevant enterprise control plane and current public reporting indicates urgent remediation value. Lost Boys Cyber rates this as ****HIGH**** priority for teams that operate Synacor Zimbra Collaboration Suite (ZCS) Classic UI or adjacent managed services.

The immediate defender objective is to confirm exposure, apply vendor remediation, review authentication and access logs for anomalous activity, and reduce management-plane reachability. This report uses source expansion beyond the last 24-72 hours where needed because authoritative CVE, vendor, and advisory pages may predate today's operational prioritization.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2025-66376
Product / Component	Synacor Zimbra Collaboration Suite (ZCS) Classic UI
Weakness	Stored cross-site scripting via CSS @import directives in HTML email
Severity	High
Affected Versions	ZCS 10 before 10.0.18 and 10.1 before 10.1.13 per advisory records
Fixed Versions	ZCS 10.0.18 and 10.1.13 or later; disable Classic UI exposure where patching is delayed
Disclosure / Advisory Window	Current operational review on 2026-08-01; see references
Exploitation Status	CISA and security reporting describe Russian state-supported phishing activity combining Zimbra webmail targeting with CVE-2025-66376 exploitation

3. Source Review & Confidence

Source	Contribution	Confidence
CISA AA26-204A	Primary government advisory on Russian state-supported Zimbra targeting.	High
NVD	CVE/KEV record and vulnerability metadata.	High
GitHub Advisory	Affected version and flaw summary.	Medium
BleepingComputer	Operational exploitation context.	Medium

Confidence is highest for product scope and mitigation statements taken from vendor/NVD/advisory material. Exploitation and campaign context is treated as operationally useful but should be validated against local telemetry before incident declaration.

4. Vulnerability Details

The flaw creates a security-control-plane exposure that can allow unauthorized access or attacker-controlled content to affect a trusted administrative or communications workflow. The impact depends on version, exposure, compensating controls, and whether the affected interface is reachable by untrusted users.

5. Attack Scenarios

- Internet-exposed or broadly reachable systems are probed shortly after public advisory coverage and used for initial access or sensitive-data collection.
- An attacker combines the vulnerability with phishing, credential reuse, or weak segmentation to pivot from the affected service into downstream identity, email, or security-management workflows.
- A managed-service or shared-administration environment amplifies impact because one compromised console or mail system can expose multiple tenants or business units.

6. Threat Landscape & Exploitation Status

CISA and security reporting describe Russian state-supported phishing activity combining Zimbra webmail targeting with CVE-2025-66376 exploitation. Defender prioritization should therefore focus on exploitability in the local environment rather than CVSS alone. Asset owners should preserve logs before patching when compromise is plausible.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Internet-facing instance	Rapid scanning and opportunistic exploitation are plausible after public advisory coverage.
Internal but high-value workflow	Security, email, or management systems are useful post-compromise pivots even when not internet-facing.
Patched / compensating-control case	Residual risk shifts to log review, credential rotation, and validation that mitigations reached all instances.

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Platform owner	Apply vendor fixed releases or mitigations and confirm affected build numbers.
High	Network/security engineering	Restrict management or webmail surfaces to trusted networks and enforce MFA where supported.
High	SOC	Review authentication, web, and device-management logs for anomalous access around the exposure window.
Medium	GRC / vendor management	Validate MSP and supplier exposure for email infrastructure, defense industrial base, government and education mail users.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
--------	------------------	---------------

Unexpected login to affected management or web service	Authentication / appliance / web logs	Identify exploitation or credential abuse after disclosure.
New administrative session from rare ASN/country/user-agent	SIEM identity/network telemetry	Surface suspicious management-plane access.
Post-access configuration export, mailbox access, or sensitive-data read	Application audit logs	Identify likely attacker objectives.

9.2. Sigma / Detection Rule

<pre> title: Suspicious Access To Priority Vulnerability Exposed Service status: experimental description: Flags unusual access to a service under active daily vulnerability review. logsource: category: webserver detection: selection_path: cs-uri-stem contains: - '/login' - '/webmail' - '/api' - '/admin' filter_known_admin: src_ip cidr: - '10.0.0.0/8' - '192.168.0.0/16' condition: selection_path and not filter_known_admin level: high </pre>
--

9.3. Hunt Query

<pre> DeviceNetworkEvents where Timestamp > ago(14d) where RemoteUrl has_any ("fmc", "zimbra", "webmail", "admin") or RemotePort in (443, 8443, 9443) summarize connections=count(), firstSeen=min(Timestamp), lastSeen=max(Timestamp) by DeviceName, InitiatingProcessAccountName, RemoteUrl, RemoteIP, RemotePort where connections > 5 </pre>
--

10. Threat Hunting

10.1. Hunt Hypothesis

If CVE-2025-66376 was exposed, successful or attempted exploitation will be followed by unusual authenticated sessions, configuration reads, webmail access, or administrative actions from infrastructure not normally used by administrators.

10.2. Hunt Query

<pre> SigninLogs where TimeGenerated > ago(30d) where AppDisplayName has_any ("Zimbra", "Cisco", "Firewall", "Webmail", "Management") or ResourceDisplayName has_any ("Zimbra", "FMC") summarize attempts=count(), failures=countif(ResultType != 0), successes=countif(ResultType == 0) by UserPrincipalName, IPAddress, AppDisplayName, bin(TimeGenerated, 1h) where successes > 0 or failures > 10 </pre>

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Vulnerable service can be reached by

		untrusted users in exposed deployments.
T1078	Valid Accounts	Static credentials or stolen webmail/application sessions can appear as legitimate logins.
T1005	Data from Local System	Attackers may read sensitive configuration, mailbox, or application data after access.

12. Validation / Lab Testing

No exploit reproduction was performed in this automated daily run. Validation completed: source review, exposure-path analysis, and render/QA verification of the final PDF. Operational use requires local asset/version validation.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Asset owner	Confirm whether Synacor Zimbra Collaboration Suite (ZCS) Classic UI exists and is affected.
Critical	Patch/change team	Apply vendor remediation or documented workaround.
High	SOC	Execute the included hunt queries for the last 14-30 days.
High	Incident lead	Preserve logs and rotate relevant credentials if suspicious access is found.

14. References

- [1] CISA AA26-204A: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa26-204a>
- [2] NVD: <https://nvd.nist.gov/vuln/detail/CVE-2025-66376>
- [3] GitHub Advisory: <https://github.com/advisories/GHSA-h7wg-85fj-3c6g>
- [4] BleepingComputer: <https://www.bleepingcomputer.com/news/security/russian-hackers-exploit-zimbra-zero-click-flaw-for-email-theft/>